Microsoft 365 Copilot Secure Adoption & Governance — Government (GCC High)

Implementation Solution Guide

Version 1.0.0 · 2026-07-01

Contents

Executive Summary — Microsoft 365 Copilot Secure Adoption & Governance (Government / GCC High) 4

- The situation . . . 4
- What this solution delivers . . . 4
- Why the Government edition is different (and necessary) . . . 4
- The bottom line . . . 5

Solution Overview — Microsoft 365 Copilot Secure Adoption & Governance (Government / GCC High) 5

- What this solution does . . . 5
- Commercial vs GCC High — what's different . . . 6
- The deployment model (all editions) . . . 7
- Named objects you will create and reuse . . . 8
- What you get . . . 8

Requirements Guide — Microsoft 365 Copilot Secure Adoption & Governance (GCC High) 8

- R1. GCC High tenant (Entra ID **for Government**) . . . 9
- R2. Copilot-eligible base licensing (GCC High) . . . 9
- R3. Administrative roles (least privilege) . . . 9
- R4. Sovereign portal access (all `*.us`) . . . 10
- R5. Network access to US Gov endpoints . . . 10
- R6. Microsoft Graph PowerShell — US Gov environment . . . 10
- R7. SharePoint / OneDrive governance baseline . . . 10
- R8. Microsoft Purview — sensitivity labels & DLP (GCC High) . . . 10
- R9. A CUI sensitivity-label taxonomy (organization-mandated) . . . 11
- R10. Pilot & expansion security groups . . . 11
- R11. Change control (authentication- and access-impacting) . . . 11

Implementation Guide — Microsoft 365 Copilot Secure Adoption & Governance (GCC High) 11

- Phase 0 — Assess (do this before enabling Copilot for anyone) . . . 12
- Phase 1 — Configure the guardrails (GCC High portals) . . . 12
- Phase 2 — Pilot (named group only) . . . 14
- Phase 3 — Validate (pass/fail gate) . . . 14
- Phase 4 — Expand (controlled waves) . . . 15
- Post-implementation . . . 15

Testing Guide — Microsoft 365 Copilot Secure Adoption & Governance (GCC High) 15

- Test suite A — Governance posture (run `COPILOTG-Validation.ps1`) . . . 15
- Test suite B — Oversharing behavior (manual, the core proof) . . . 16

Test suite C — GCC High parity expectations (verify, don't assume) . . . 17
Test suite D — Evidence report . . . 17
Troubleshooting Guide — Microsoft 365 Copilot Secure Adoption & Governance (GCC High) 18
T1. Scripts return empty results (or "tenant not found") but no obvious error . . . 18
T2. A portal shows the wrong tenant, or won't load your tenant . . . 18
T3. `Connect-MgGraph -Environment USGov` fails to authenticate . . . 18
T4. Restricted SharePoint Search option is missing . . . 18
T5. Copilot doesn't activate for a licensed pilot user . . . 19
T6. Copilot won't return live/web information . . . 19
T7. Teams meeting Copilot is missing for pilot users . . . 19
T8. A Copilot Studio / agent capability isn't available . . . 19
T9. DLP policy "isn't doing anything" . . . 19
T10. Sensitivity label not appearing for users . . . 19
T11. Remediation script made a change you didn't expect . . . 20
Escalation checklist . . . 20
Best Practices — Microsoft 365 Copilot Secure Adoption & Governance (GCC High) 20
Govern before you grant . . . 20
Use the sovereign surfaces correctly . . . 20
Respect the parity gaps (don't over-promise) . . . 21
Roll out with gates . . . 21
Operate it as ongoing hygiene . . . 21
Deliverables Summary — Microsoft 365 Copilot Secure Adoption & Governance (GCC High) 22
Documents . . . 22
PowerShell scripts (`scripts/`) . . . 22
How they work together . . . 23
Named objects (used consistently across all deliverables) . . . 23
Definition of done . . . 23
Appendix A — PowerShell Scripts 24

Executive Summary — Microsoft 365 Copilot Secure Adoption & Governance (Government / GCC High)

The situation

Microsoft 365 Copilot is now **generally available in GCC High** (GA December 2025, after GCC and DoD). Government organizations can adopt it today — but on a tenant that handles **Controlled Unclassified Information (CUI)**, adoption without governance is a risk, not a win. Copilot reasons over **everything a user can already open**. If SharePoint and OneDrive permissions are loose, Copilot becomes the fastest path yet to surface content a user could technically reach but was never meant to see. In a CUI environment, that is a spillage exposure.

What this solution delivers

A **self-guided, tested** program to adopt Copilot **securely** on GCC High, authored specifically for the **US sovereign cloud** — not Commercial steps with a different sign-in. It covers:

- **Assess** oversharing and classification posture **before** any user is licensed.
- **Configure** the guardrails — **sensitivity labels**, **DLP**, and **Restricted SharePoint Search — using the correct** `*.us` GCC High portals (`compliance.microsoft.us`, `portal.office365.us`, `entra.microsoft.us`, and others).
- **Pilot** with a named security group, **Validate** with pass/fail gates, and **Expand** in controlled waves.
- **Five PowerShell scripts** (Discovery, Validation, Report, Remediation, Set-ScopeTargeting) that connect to **US Gov Microsoft Graph** (`-Environment USGov`) — read-only by default, with remediation gated behind `-WhatIf`.

Why the Government edition is different (and necessary)

GCC High is **not** the Commercial portal with a different login. This edition explicitly handles:

- **Different portals** — every admin surface is a `*.us` sovereign URL; Commercial URLs fail or sign you into the wrong tenant.
- **US Gov Graph** — scripts use `-Environment USGov`; Commercial Graph will not resolve the tenant.
- **Web grounding OFF by default** — Copilot answers from tenant content only unless you explicitly enable and accept web grounding; plan for a knowledge cutoff.
- **Feature parity lag** — Teams-meeting Copilot, several Copilot Studio/agent surfaces, and Wave 2 features are limited, staged, or not yet available; the solution flags each with **verify for GCC High** rather than assuming.
- **Stricter compliance framing** — FedRAMP High, DFARS, ITAR/EAR, CMMC — which is exactly why the

pilot gate and validation evidence are mandatory.

Every parity claim is **cited** to Microsoft documentation (see the *GCC High parity notes*).

The bottom line

Microsoft 365 Copilot adopted correctly on GCC High — right portals, right endpoints, oversharing remediated, labels and DLP enforced, parity gaps handled — and **proven on a pilot before you scale.** Self-guided, tested, at a fraction of consulting cost.

Solution Overview — Microsoft 365 Copilot Secure Adoption & Governance (Government / GCC High)

This is the **Government (GCC High)** edition of *Microsoft 365 Copilot Secure Adoption & Governance*. It takes the same discipline — get your data estate governed *before* you turn Copilot loose on it — and re-authors every step for the **US sovereign cloud (GCC High)**: the correct `*.us` admin portals, the US Gov Microsoft Graph endpoints (`-Environment USGov`), and the **Commercial-vs-GCC-High parity gaps** that make Commercial click-paths silently fail on a government tenant.

> ***Read this first — Copilot availability in GCC High (as of this writing, verify for your tenant).*** *Microsoft 365 Copilot **reached general availability in GCC High in December 2025**, after earlier launches in GCC and DoD. So Copilot *is* available on GCC High today — this is **not** a "wait until it ships" solution. **But** two things are true at once, and both shape this guide: 1. **Copilot is live**, so the governance work here (oversharing remediation, sensitivity labels, Restricted SharePoint Search) is not hypothetical — it is the gate you must clear *before* users start prompting against your CUI. 2. **GCC High is not at feature parity with Commercial.** Several capabilities are OFF by default, limited, or not yet available (web grounding, some Copilot Studio surfaces, Teams meeting Copilot, Wave 2 features). Those gaps are called out inline where they matter. Source: [Microsoft — M365 Copilot is now available in GCC High](https://techcommunity.microsoft.com/blog/publicsectorblog/microsoft-365-copilot-is-now-available-in-gcc-high/4473310) and [Understand Microsoft US government cloud environments](https://learn.microsoft.com/en-us/microsoft-365/copilot/gov-overview). **Always verify current availability for your own GCC High tenant** — the roadmap moves.*

What this solution does

Microsoft 365 Copilot answers a user's prompt by reasoning over **everything that user can already open** — every SharePoint site, Teams channel, and OneDrive file their account has access to. In a government tenant that reasons over **CUI**, that is exactly the risk: if permissions are loose, Copilot becomes a very fast way to surface content a user could *technically* reach but was never meant to see. This solution puts the **governance guardrails** in place first, then adopts Copilot in a controlled, piloted, validated way:

- **Assess** the oversharing exposure and label/DLP posture *before* Copilot is enabled for anyone.
- **Configure** the guardrails — sensitivity labels, DLP, Restricted SharePoint Search (RSS),

Copilot-relevant Purview and SharePoint controls — using the **GCC High portals**.

- **Pilot** Copilot with a **named security group** (`SG-COPILOTG-Pilot`), not the whole tenant.

- **Validate** with the included scripts and manual checks (pass/fail gates).
- **Expand** in controlled waves, each gated on the prior wave's results.

The deliverables — this guide, the requirements and implementation guides, the testing and troubleshooting guides, and **five PowerShell scripts** — are all authored for GCC High.

Commercial vs GCC High — what's different

This is the section that saves you from following a Commercial tutorial into a dead end. If you have run Copilot governance on a Commercial tenant, **assume nothing carries over unchanged.**

1. The admin portals are different URLs (`*.us`, not `.com`)

Every portal you touch has a sovereign-cloud address. Using the Commercial URL will either fail to load your tenant or, worse, sign you into the wrong tenant.

Purpose	Commercial (do **not** use)	GCC High (use this)
Sign-in / identity authority	`login.microsoftonline.com`	`login.microsoftonline.us`
Microsoft 365 admin center	`admin.microsoft.com`	`portal.office365.us`
Microsoft Entra admin center	`entra.microsoft.com`	`entra.microsoft.us`
Microsoft Purview	`purview.microsoft.com` / `compliance.microsoft.com`	`compliance.microsoft.us`
Microsoft Defender	`security.microsoft.com`	`security.microsoft.us`
Intune / Endpoint	`intune.microsoft.com` / `endpoint.microsoft.com`	`endpoint.microsoft.us`
Azure portal	`portal.azure.com`	`portal.azure.us`
Copilot Studio	`copilotstudio.microsoft.com`	`high.powerva.microsoft.us`
Power Platform admin	`admin.powerplatform.microsoft.com`	`high.admin.powerplatform.microsoft.us`

Source for the sovereign portal set: [Microsoft US Gov cloud overview](https://learn.microsoft.com/en-us/microsoft-365/copilot/gov-overview) and [Copilot Studio US Government service URLs](https://learn.microsoft.com/en-us/microsoft-copilot-studio/requirements-licensing-gcc). **Verify each portal loads *your* GCC High tenant before configuring anything.**

2. Identity is Entra ID for Government

GCC High uses **Microsoft Entra ID for Government** (the US Gov sovereign directory), not the public Entra ID that GCC uses. Scripts must connect to the **US Gov Graph** with `-Environment USGov`;

Commercial Graph calls will not resolve your tenant. (Source: [Copilot Studio US Gov requirements](https://learn.microsoft.com/en-us/microsoft-copilot-studio/requirements-licensing-gcc).)

3. Web grounding is OFF by default in GCC High

To keep sensitive government data inside the compliance boundary, Microsoft ships Copilot to GCC High with **web grounding OFF by default**. Practically: Copilot answers only from tenant content (and its trained model), so responses can be subject to a **knowledge cutoff** and may be dated. Do not design adoption around "Copilot will look it up on the web" — plan for **tenant-grounded answers only** unless your organization explicitly enables and accepts web grounding. (Source: [M365 Copilot in GCC High](https://techcommunity.microsoft.com/blog/publicsectorblog/microsoft-365-copilot-is-now-available-in-gcc-high/4473310).)

4. Feature parity lags — several surfaces are limited or not yet available

Release timing in GCC High typically **lags Commercial**, and some integrations are more restricted by design. At the time of writing:

- **Copilot in Microsoft 365 apps** (Word, Excel, PowerPoint, Outlook) and **Copilot Chat**

(work grounding)** are available in GCC High.

- **Teams meeting Copilot** and **Copilot in Teams chat/channels** have historically been

limited or not yet available in GCC High — **verify current status for your tenant.**

- **Copilot Studio / agents in GCC High** are **more restricted** than Commercial: the Copilot

Studio **Teams app experience**, the **Teams & M365 Copilot channel**, **Copilot agents that extend M365**, **Prompt Action**, and **transfer-to-agent** are listed **not available in GCC High**; **triggers / autonomous agents** and **Azure AI Search as a knowledge source** are not available in GCC or GCC High. (Source: [Copilot Studio US Gov feature limitations](https://learn.microsoft.com/en-us/microsoft-copilot-studio/requirements-licensing-gcc).)

- **Wave 2 features** (e.g. GPT-5, image generation, code interpreter, Researcher/Analyst agents)

are staged into GCC High through **H1 2026** — **verify what has actually landed** before you promise it to users. (Source: [M365 Copilot in GCC High](https://techcommunity.microsoft.com/blog/publicsectorblog/microsoft-365-copilot-is-now-available-in-gcc-high/4473310).)

> ***Authoring rule for this whole solution:*** *where a step depends on a capability that may not be at parity, the guide says so and tells you to* ***verify for GCC High*** *rather than assuming. We never invent a GCC High behavior we could not cite.*

5. Compliance framing is stricter

GCC High is built for **FedRAMP High, DFARS, ITAR/EAR, and CMMC** workloads handling **CUI**. That raises the stakes on the governance work: an oversharing gap is not just an IT hygiene issue, it is a potential **CUI spillage** path once Copilot can reason over it. Treat the pilot gate as mandatory.

The deployment model (all editions)

Assess → **Configure** → **Pilot** → **Validate** → **Expand**, with a gate at each arrow. You do not enable Copilot for a user until the data those users can reach has been assessed and remediated, and you do not

expand past the pilot until validation passes. This edition simply runs that model on the **GCC High portals and US Gov Graph endpoints**.

Named objects you will create and reuse

Object	Name	Used for
Pilot security group	`SG-COPILOTG-Pilot`	First wave of Copilot-licensed users
Expansion security group	`SG-COPILOTG-Wave2`	Second controlled wave
Sensitivity label (baseline)	`CUI//BASIC` (or your org's CUI label set)	Labeling CUI so DLP/Copilot honor it
RSS allow-list	`Copilot Search Allowed Sites`	Sites Copilot may search once RSS is on

Names are used consistently across the implementation, testing, troubleshooting, and script docs so a novice admin can follow one thread end to end. Substitute your organization's own CUI label taxonomy where indicated — **do not invent a label scheme; use the one your program already mandates.**

What you get

1. This **Solution Overview** (Commercial-vs-GCC-High differences, Copilot availability caveat).
2. **Requirements Guide** — every prerequisite, how to verify and how to implement, GCC High licensing (G3/G5 Gov + Copilot add-on), roles, sovereign portal access, endpoints.
1. **Implementation Guide** — ordered steps on the GCC High portals with parity caveats inline.
2. **Testing Guide** — pass/fail validation gates.
3. **Troubleshooting Guide** — GCC-High-specific gotchas.
4. **Best Practices** and a **Deliverables Summary**.
5. **GCC High parity notes** (cited reference).
6. **Five PowerShell scripts** — Discovery, Validation, Report, Remediation, Set-ScopeTargeting — all connecting to **US Gov Graph** (`-Environment USGov`).

Requirements Guide — Microsoft 365 Copilot Secure Adoption & Governance (GCC High)

Confirm **every** requirement below before you configure anything. This is the Government (GCC High) edition, so each item is written for the **US sovereign cloud** — the `*.us` portals and the US Gov Graph. The **category-level** prerequisites (Entra tenant, admin roles, pilot group, network access, change control) are in `global-requirements-security.md`; this guide adds the **Copilot- and GCC-High-specific** requirements.

Each entry follows the house format: **Description · Why · Verify · Implement-if-missing.**

> ***Portal note:*** *wherever the global requirements say* `entra.microsoft.com`*,* `intune.microsoft.com`*, etc., substitute the GCC High URL from the table in the Solution Overview (*`entra.microsoft.us`*,* `endpoint.microsoft.us`*,* `compliance.microsoft.us`*,* `portal.office365.us`*).*

R1. GCC High tenant (Entra ID for Government)

Description: An active Microsoft 365 **GCC High** tenant using **Microsoft Entra ID for Government**. **Why:** Copilot and its governance controls operate entirely inside the sovereign boundary; a Commercial or GCC tenant is a different environment with different portals and identity authority. **Verify:** Sign in to `https://portal.office365.us` and `https://entra.microsoft.us` as an admin and confirm the tenant is a **GCC High** tenant (tenant type / domain suffix reflects your Gov tenant). **Implement:** Onboard to GCC High through an authorized Microsoft Gov reseller/CSP; eligibility is validated (ITAR/CUI handling). (Source: [Copilot Studio US Gov customer eligibility](https://learn.microsoft.com/en-us/microsoft-copilot-studio/requirements-licensing-gcc).)

R2. Copilot-eligible base licensing (GCC High)

Description: Users need an **eligible GCC High base plan** *plus* the **Microsoft 365 Copilot add-on**. **Why:** Copilot is an add-on; the base plan supplies the workloads (Exchange, SharePoint, OneDrive, Teams, Office apps) Copilot reasons over. **Verify:** In `https://portal.office365.us` → **Billing** → **Licenses**, confirm eligible base plans (e.g. **Microsoft 365 G3 / G5**, or eligible Office 365 G-plans) and the **Microsoft 365 Copilot** add-on are present. Microsoft lists GCC/GCC High/DoD Copilot as an add-on to **Microsoft 365 G3, G5, F1** and **Office 365 G1/G3/G5/F3** (among others). (Source: [Microsoft 365 Copilot licensing — US Government licenses](https://learn.microsoft.com/en-us/microsoft-365/copilot/microsoft-365-copilot-licensing).) **Implement:** Purchase eligible base + Copilot add-on through your Gov CSP/VL channel.

> ***Parity note — plan for what each SKU includes. G5 (GCC High)*** *includes the Purview and Defender suites Copilot leans on for sensitivity labeling, DLP, and threat protection;* ***G3*** *typically requires* ***Defender Suite GCCH*** *and* ***Purview Suite GCCH*** *add-ons to reach comparable coverage. Confirm your SKU actually includes the Purview capabilities this solution configures, or budget the add-ons.* ***Verify for your contract*** *— licensing bundles change. (General guidance; confirm current SKU contents with your licensing desk.)*

R3. Administrative roles (least privilege)

Description: The operator holds the right **Entra for Government** admin roles. **Why:** Configuring labels, DLP, SharePoint/Copilot search controls, and assigning Copilot licenses each require specific privileges; use least privilege, not blanket Global Admin. **Verify:** In `https://entra.microsoft.us` → **Roles and administrators**, confirm the operator has the roles needed for the tasks below. **Implement:** Assign the minimum roles:

- **Compliance Administrator** (or **Compliance Data Administrator**) — sensitivity labels & DLP in Purview (`compliance.microsoft.us`).
- **SharePoint Administrator** — Restricted SharePoint Search and site-level controls.

- **License / User Administrator** — assign Copilot licenses.
- Reserve **Global Administrator** for tenant-wide switches only.

R4. Sovereign portal access (all `*.us`)

Description: The operator can reach every GCC High portal this solution uses. **Why:** A Commercial URL will not administer a GCC High tenant. **Verify:** Confirm each of these loads *your* tenant: `portal.office365.us`, `entra.microsoft.us`, `compliance.microsoft.us`, `security.microsoft.us`, `endpoint.microsoft.us`, `portal.azure.us`, and (if using agents) `high.powerva.microsoft.us`. **Implement:** Correct bookmarks/allow-lists to the `*.us` set; remove Commercial URLs to avoid misconfiguration.

R5. Network access to US Gov endpoints

Description: Outbound HTTPS to the **US Government** service endpoints, not the Commercial ones. **Why:** Sign-in, Graph, Purview, SharePoint, and Copilot traffic in GCC High use `*.us` / `*.usgovcloudapi.net` endpoints; filtering only Commercial ranges will break the tenant. **Verify:** From an admin workstation, reach `https://login.microsoftonline.us` and `https://graph.microsoft.us`. **Implement:** Allow the US Gov endpoint set through proxy/firewall, including (per Microsoft's Gov URL guidance) `*.microsoft.us`, `*.azure.us`, `*.usgovcloudapi.net`, `*.windows.net`, and the `AzureCloud.usgovvirginia` / `AzureCloud.usgovtexas` IP ranges. (Source: [Copilot Studio US Gov service URLs & IP ranges](https://learn.microsoft.com/en-us/microsoft-copilot-studio/requirements-licensing-gcc).)

R6. Microsoft Graph PowerShell — US Gov environment

Description: The **Microsoft.Graph** PowerShell SDK, able to connect with `-Environment USGov`. **Why:** All five scripts read/write via **US Gov Graph** (`graph.microsoft.us`); the default (Global) environment will not resolve a GCC High tenant. **Verify:** In PowerShell: `Get-Module Microsoft.Graph -ListAvailable`, then `Connect-MgGraph -Environment USGov -Scopes "Sites.Read.All"` succeeds and `(Get-MgEnvironment -Name USGov).GraphEndpoint` shows `https://graph.microsoft.us`. **Implement:** `Install-Module Microsoft.Graph -Scope CurrentUser`. The scripts always pass `-Environment USGov`; **never** run them against the default environment.

R7. SharePoint / OneDrive governance baseline

Description: SharePoint Online (GCC High) with the ability to set tenant search and site-level controls. **Why:** Copilot's reach *is* SharePoint/OneDrive access; Restricted SharePoint Search and site permissions are the primary guardrails. **Verify:** SharePoint admin center (from `portal.office365.us` → **Admin centers** → **SharePoint**) loads and you can open **Settings** and **More features** → **Restricted SharePoint Search**. **Implement:** Ensure SharePoint Administrator role (R3) and that RSS is available in your tenant — **verify for GCC High**, as feature availability can lag.

R8. Microsoft Purview — sensitivity labels & DLP (GCC High)

Description: Purview in GCC High (`compliance.microsoft.us`) with **sensitivity labels** and **DLP** available. **Why:** Labels and DLP are how CUI is marked and how Copilot output/access respects classification; they are the substance of "secure adoption." **Verify:** `https://compliance.microsoft.us` loads; **Information protection** → **Labels** and **Data loss prevention** → **Policies** are accessible. **Implement:** Confirm your SKU includes Purview Information Protection + DLP (see R2 parity note); add the Purview Suite GCCH add-on if on G3 without it.

R9. A CUI sensitivity-label taxonomy (organization-mandated)

Description: Your program's **existing CUI label scheme** (e.g. a `CUI//BASIC` baseline label and any specified categories). **Why:** GCC High tenants handle CUI; Copilot governance must honor the *mandated* classification — not one invented for this project. **Verify:** Confirm which label taxonomy your organization/contract requires. **Implement:** Use the mandated taxonomy in Purview. **Do not invent a label scheme.** Where this solution names a label, it is a placeholder for your mandated one.

R10. Pilot & expansion security groups

Description: Named Entra security groups for staged rollout: `SG-COPILOTG-Pilot` and `SG-COPILOTG-Wave2`. **Why:** Copilot is licensed and enabled by assignment; a named group is how you keep the pilot bounded and expansion controlled. **Verify:** `https://entra.microsoft.us` → **Groups** shows both groups. **Implement:** Create them (or let `COPILOTG-Set-ScopeTargeting.ps1` build/populate them — it runs **-WhatIf by default**).

R11. Change control (authentication- and access-impacting)

Description: A documented change/rollback process (per global requirement G8) covering label, DLP, and search-scope changes. **Why:** RSS and DLP changes alter what users and Copilot can find; a bad rollout can hide needed content or expose CUI. A pilot gate and rollback are mandatory. **Verify:** A change ticket exists with approver, window, and rollback step. **Implement:** Record the change, name the pilot group, define rollback, get approval before production assignment.

Gate to proceed: R1–R11 all pass (or documented as N/A with reason). Only then move to the Implementation Guide.

Implementation Guide — Microsoft 365 Copilot Secure Adoption & Governance (GCC High)

This is the ordered, click-by-click implementation for a **GCC High** tenant. Every portal path uses the `*.us` **sovereign URLs**, and every script step connects to **US Gov Graph** (`-Environment USGov`). GCC-High-specific caveats appear **inline at the step where they matter** — do not skip them.

Follow the deployment model with a **gate at each arrow**: **Assess** → **Configure** → **Pilot** → **Validate** → **Expand.**

> ***Before you start:*** *complete the Requirements Guide (R1–R11). You need Compliance Administrator, SharePoint Administrator, and license-assignment rights, plus the Microsoft.Graph module able to connect with* `-Environment USGov`*.*

> ***Availability reminder:*** *Copilot is GA in GCC High (Dec 2025), but feature parity lags Commercial and web grounding is OFF by default. Where a step depends on a capability that may not be at parity, it says* ***verify for GCC High****. See the GCC High parity notes doc for the cited detail.*

Phase 0 — Assess (do this before enabling Copilot for anyone)

Step 0.1 — Run Discovery (read-only)

Get a factual picture of your oversharing exposure and governance posture **before** any user gets a Copilot license.

1. Open PowerShell on an admin workstation with US Gov network access (R5).
2. Run:

```
powershell -ExecutionPolicy Bypass -File .\COPILOTG-Discovery.ps1
```

The script calls `Connect-MgGraph -Environment USGov` and enumerates (read-only): SharePoint sites with broad/"Everyone except external users" sharing, sites without sensitivity labels, OneDrive sharing posture, and current Copilot license assignments.

1. Review the CSV/console output. **Sites flagged as broadly shared are your remediation backlog —**

these are exactly where Copilot could surface content too widely once enabled.

> ***GCC High caveat:*** *Discovery reads via* `graph.microsoft.us`*. If you see empty results but no error, confirm you connected to* ***USGov****, not the default environment (see Troubleshooting T1).*

Step 0.2 — Record the baseline

Save the Discovery output as your **pre-change baseline**. You will re-run Discovery/Validation after remediation to prove the gap closed. This is your Assess-phase gate evidence.

Phase 1 — Configure the guardrails (GCC High portals)

Step 1.1 — Create / confirm the CUI sensitivity label in Purview

1. Go to `https://compliance.microsoft.us` (Microsoft Purview, GCC High) → sign in.
2. Left nav: **Information protection** → **Labels**.
3. If your mandated CUI label (e.g. `CUI//BASIC`, per R9) does not exist, select **Create a label**

and build it to your **organization's mandated taxonomy** — **do not invent one.**

1. Configure the label's protection to your program's requirements (encryption/marking as mandated).
2. **Information protection** → **Label policies** → **Publish labels** → publish to the pilot group

`SG-COPILOTG-Pilot` first (not the whole tenant).

> ***GCC High caveat:*** *Purview label and DLP feature availability can lag Commercial. If a label option you expect is missing,* ***verify for GCC High*** *before assuming misconfiguration.*

Step 1.2 — Create a DLP policy that respects the label

1. In `https://compliance.microsoft.us` → **Data loss prevention** → **Policies** → **Create policy**.
2. Scope it to **SharePoint sites**, **OneDrive**, and **Teams** locations.
3. Base the rule on your **CUI sensitivity label** so content marked CUI is protected consistently.

Name it `DLP-COPILOTG-CUI`.

1. Start in **Test / simulation** mode, review matches, then enforce. Record the change (R11).

Step 1.3 — Turn on Restricted SharePoint Search (RSS) to bound Copilot's reach

Restricted SharePoint Search limits **tenant-wide** Copilot/enterprise search to an **allow-list** of curated sites while you remediate the rest — a fast way to shrink Copilot's blast radius during adoption.

1. From `https://portal.office365.us` → **Admin centers** → **SharePoint**.
2. **Settings** → **Search** (or **More features** → **Restricted SharePoint Search** depending on tenant

layout) → **enable Restricted SharePoint Search**.

1. Add your vetted, correctly-permissioned sites to the allow-list `Copilot Search Allowed Sites`

(up to the documented site cap).

1. Save and record the change (R11).

> ***GCC High caveat — verify for GCC High:*** *Restricted SharePoint Search availability and its site cap can differ or lag in GCC High. Confirm the feature is present in **your** SharePoint (GCC High) admin center before relying on it as your primary guardrail. If unavailable, fall back to tightening site permissions directly (Step 1.4) until RSS lands. (See parity notes doc.)*

Step 1.4 — Remediate the broadly-shared sites from Discovery

For each site flagged in Step 0.1:

1. Tighten membership/permissions to the intended audience (remove "Everyone except external users"

where not warranted).

1. Apply the correct **sensitivity label** at the site/library level.
2. Where you cannot immediately fix a site, **exclude it from the RSS allow-list** so Copilot cannot

search it yet.

You can drive the safe, reviewable portion of remediation with the Remediation script (Step 1.5), which runs **-WhatIf by default**.

Step 1.5 — Run Remediation in preview, then apply

1. Preview only (default, no changes):

```
powershell -ExecutionPolicy Bypass -File .\COPILOTG-Remediation.ps1
```

It connects with `-Environment USGov` and **reports** what it *would* change (e.g. flag sites to remove from the allow-list, sites missing labels).

1. Review the preview against your change ticket.
2. Only when approved, re-run with the explicit apply switch the script documents in its header

(e.g. `-Apply` / `-Confirm`), never blindly. Record results (R11).

> ***Safety:*** *Remediation and Set-ScopeTargeting* ***default to -WhatIf****. Applying is an explicit, deliberate second run.*

Phase 2 — Pilot (named group only)

Step 2.1 — Build/populate the pilot group

```
powershell -ExecutionPolicy Bypass -File .\COPILOTG-Set-ScopeTargeting.ps1
```

By default this runs **-WhatIf** and shows the membership it *would* set for `SG-COPILOTG-Pilot`. Review, then re-run with the documented apply switch to create/populate the group.

Step 2.2 — Assign Copilot licenses to the pilot group only

1. `https://portal.office365.us` → **Billing** → **Licenses** → **Microsoft 365 Copilot**.
2. Assign the **Microsoft 365 Copilot** add-on to members of `SG-COPILOTG-Pilot` (group-based

licensing via Entra `https://entra.microsoft.us` → **Groups** → **SG-COPILOTG-Pilot** → **Licenses** is the cleaner path).

1. Confirm each pilot user also holds an **eligible base plan** (R2) — Copilot will not activate

without it.

> ***GCC High caveat:*** *Copilot in* ***Word/Excel/PowerPoint/Outlook*** *and* ***Copilot Chat (work grounding)*** *are available.* ***Teams meeting Copilot / Copilot in Teams chat/channels*** *have been* ***limited or not yet available*** *in GCC High —* ***do not promise Teams-meeting Copilot to pilot users until you verify it for your tenant.*** *(See parity notes.)*
>
> ***GCC High caveat — web grounding OFF:*** *pilot users get* ***tenant-grounded*** *answers by default. Set expectations: no live web lookups unless your org explicitly enabled web grounding and accepted the data-boundary tradeoff.*

Step 2.3 — Confirm Copilot activation

Have a pilot user open Word/Outlook (GCC High) and confirm the Copilot experience appears, and that Copilot Chat only returns content the user is entitled to.

Phase 3 — Validate (pass/fail gate)

Step 3.1 — Run Validation

```
powershell -ExecutionPolicy Bypass -File .\COPILOTG-Validation.ps1
```

Connects with `-Environment USGov` and checks (read-only): RSS enabled and scoped; CUI label published; DLP policy present and enforced; Copilot licenses only on the intended group; no broadly-shared site remains inside the RSS allow-list. Output is **pass/fail per check.**

Step 3.2 — Manual spot-check

As a pilot user, prompt Copilot to surface content from a site you **deliberately kept out** of the allow-list / that the user shouldn't reach — confirm Copilot **cannot** surface it. This is the core "no oversharing" proof.

Step 3.3 — Produce the report

```
powershell -ExecutionPolicy Bypass -File .\COPILOTG-Report.ps1
```

Generates a consolidated **evidence report** (posture + validation results) for your change record and leadership sign-off.

Gate: All Validation checks pass and the manual spot-check confirms no oversharing → proceed. Any fail → remediate and re-validate; do **not** expand.

Phase 4 — Expand (controlled waves)

1. Populate `SG-COPILOTG-Wave2` with `COPILOTG-Set-ScopeTargeting.ps1` (preview, then apply).
2. Assign Copilot licenses to Wave 2 via group-based licensing.
3. Add the next batch of **remediated, correctly-labeled** sites to the RSS allow-list.
4. Re-run **Validation** and **Report** after each wave — every wave is gated on clean results.
5. Continue until the estate is governed and Copilot is broadly, safely enabled.

> ***Do not** widen the RSS allow-list faster than you remediate. The allow-list is your throttle.*

Post-implementation

• Re-run **Discovery** monthly (new sites/oversharing appear over time) — treat it as ongoing hygiene, not a one-time task.

• Re-check **GCC High feature parity** each quarter as Wave 2 capabilities land; update pilot expectations when Teams-meeting Copilot / web grounding / new agents become available for your tenant.

Testing Guide — Microsoft 365 Copilot Secure Adoption & Governance (GCC High)

Testing proves the guardrails work **before** you expand Copilot past the pilot. Every check is **pass/fail** and, where possible, is produced by the included scripts (all connecting to **US Gov Graph**, `-Environment USGov`). Run these after Phase 1 (Configure) and again after each expansion wave.

> ***Portals:** validation portals are the GCC High `*.us` set — `compliance.microsoft.us`, `security.microsoft.us`, `portal.office365.us` (→ SharePoint admin), `entra.microsoft.us`.*

Test suite A — Governance posture (run `COPILOTG-Validation.ps1`)

```
powershell -ExecutionPolicy Bypass -File .\COPILOTG-Validation.ps1
```

#	Check	Pass criteria	Fail action
A1	US Gov connection	Script reports connected to `graph.microsoft.us` (USGov)	Fix connection (Troubleshooting T1); do not trust results from Global
A2	Restricted SharePoint Search	RSS **enabled** and scoped to `Copilot Search Allowed Sites`	Enable RSS (Impl. 1.3) or fall back to permission tightening; **verify for GCC High**
A3	CUI sensitivity label	Mandated CUI label **exists and is published** to pilot group	Create/publish label (Impl. 1.1)
A4	DLP policy	`DLP-COPILOTG-CUI` present and **enforced** (not just simulation)	Move policy out of test mode (Impl. 1.2)
A5	License scope	Copilot add-on assigned **only** to `SG-COPILOTG-Pilot` (and Wave groups you intend)	Remove stray assignments (Set-ScopeTargeting)
A6	Allow-list hygiene	**No** broadly-shared site from Discovery remains in the RSS allow-list	Remove/remediate the site (Impl. 1.4/1.5)

Suite A gate: all rows PASS.

Test suite B — Oversharing behavior (manual, the core proof)

These confirm Copilot's *actual* reach matches intent — the reason this solution exists.

#	Test	How	Pass criteria
B1	Kept-out site is invisible	As a pilot user, ask Copilot Chat to summarize/find content from a site **deliberately excluded** from the allow-list	Copilot **cannot** surface that content
B2	Entitlement respected	As a pilot user with no access to a specific CUI library, prompt for its content	Copilot returns **nothing** from that library

#	Test	How	Pass criteria
B3	Allowed site works	Ask Copilot about content in an **allow-listed, entitled** site	Copilot returns the expected content
B4	Label honored	Confirm a CUI-labeled document keeps its label/marking when referenced by Copilot output workflows	Label/marking persists per policy

Suite B gate: B1 and B2 PASS (no oversharing) **and** B3 PASS (Copilot still useful).

Test suite C — GCC High parity expectations (verify, don't assume)

Because parity lags Commercial, explicitly confirm what is/ isn't available so you don't promise users a capability that hasn't landed.

#	Capability	Expected in GCC High (verify for your tenant)	Test
C1	Copilot in Word/Excel/PPT/Outlook	Available	Pilot user sees Copilot in these apps
C2	Copilot Chat (work grounding)	Available	Chat returns entitled tenant content
C3	Web grounding	**OFF by default**	Confirm no live web results unless explicitly enabled; expect knowledge cutoff
C4	Teams meeting Copilot / Teams chat Copilot	**Limited / may be unavailable**	Verify status before promising; do not fail the pilot if absent
C5	Copilot Studio agents / Teams app / triggers	**Restricted** in GCC High	Confirm which agent surfaces exist before designing agents
C6	Wave 2 (GPT-5, image gen, code interpreter, Researcher/Analyst)	Staged into **H1 2026**	Verify what has actually shipped for your tenant

Source for expected parity: see the **GCC High parity notes** doc (cited). **Record the actual observed state** — availability changes over time.

Test suite D — Evidence report

```
powershell -ExecutionPolicy Bypass -File .\COPILOTG-Report.ps1
```

Produces a consolidated report of posture + Suite A results for the change record and sign-off.

Overall gate to expand: Suite A all PASS, Suite B core tests PASS, Suite C observed state recorded, Suite D report generated and attached to the change ticket. Any failure → remediate and re-test; do not proceed to the next wave.

Troubleshooting Guide — Microsoft 365 Copilot Secure Adoption & Governance (GCC High)

The failures below are the ones that specifically bite on **GCC High** — most stem from following a Commercial click-path or connecting to the wrong cloud. Each entry: **Symptom · Cause · Fix.**

T1. Scripts return empty results (or "tenant not found") but no obvious error

Symptom: Discovery/Validation run "successfully" but show no sites, no licenses, or a tenant mismatch. **Cause:** Connected to the **default (Global/Commercial) Graph environment**, not US Gov. A GCC High tenant does not exist in Commercial Graph. **Fix:** Ensure every connection uses `-Environment USGov`. Verify:

```
Connect-MgGraph -Environment USGov -Scopes "Sites.Read.All"
(Get-MgContext).Environment           # must show USGov
(Get-MgEnvironment -Name USGov).GraphEndpoint   # https://graph.microsoft.us
```

Disconnect (`Disconnect-MgGraph`) and reconnect if a prior Global session is cached.

T2. A portal shows the wrong tenant, or won't load your tenant

Symptom: `entra.microsoft.com` / `admin.microsoft.com` opens a different (or empty) tenant. **Cause:** You used a **Commercial** portal URL against a GCC High tenant. **Fix:** Use the `*.us` portal for every task: `portal.office365.us`, `entra.microsoft.us`, `compliance.microsoft.us`, `security.microsoft.us`, `endpoint.microsoft.us`, `portal.azure.us`, `high.powerva.microsoft.us`. Sign in at `login.microsoftonline.us`.

T3. `Connect-MgGraph -Environment USGov` fails to authenticate

Symptom: Auth error or endpoint unreachable when connecting to US Gov Graph. **Cause:** Network filtering allows only Commercial endpoints, or the Graph module is outdated. **Fix:** Allow the **US Gov endpoint set** through proxy/firewall — `*.microsoft.us`, `*.azure.us`, `*.usgovcloudapi.net`, `*.windows.net`, and the `AzureCloud.usgovvirginia` / `AzureCloud.usgovtexas` IP ranges. Update the SDK: `Update-Module Microsoft.Graph`. Confirm reach to `https://login.microsoftonline.us` and `https://graph.microsoft.us`.

T4. Restricted SharePoint Search option is missing

Symptom: RSS is not visible in the SharePoint (GCC High) admin center. **Cause:** Feature availability in GCC High can **lag Commercial** — or you lack the SharePoint Administrator role. **Fix:** First confirm the **SharePoint Administrator** role (`entra.microsoft.us` → Roles). If the role is correct and RSS is still absent, **verify RSS availability for GCC High** (it may not have landed for your tenant). Until it does, use

the fallback: **tighten site permissions directly** and keep unremediated sites out of Copilot's reach. (See parity notes; do not assume the Commercial behavior.)

T5. Copilot doesn't activate for a licensed pilot user

Symptom: A user in `SG-COPILOTG-Pilot` has the Copilot add-on but sees no Copilot in the apps. **Cause:** Missing **eligible base plan**, or license just assigned (propagation), or an app/channel requirement. **Fix:** Confirm the user holds an eligible GCC High base plan (G3/G5 Gov, or eligible Office 365 G-plan) **in addition to** the Copilot add-on. Allow propagation time. Use the **Copilot License Details** diagnostic. Verify the user is on a supported Microsoft 365 Apps channel/build.

T6. Copilot won't return live/web information

Symptom: Copilot answers seem dated or refuses current-events questions. **Cause: Web grounding is OFF by default in GCC High** — by design, to keep data in-boundary. **Fix:** This is expected. Copilot answers from **tenant content** (and its trained model, subject to a knowledge cutoff). Only enable web grounding if your organization explicitly accepts the data-boundary tradeoff — document that decision. Do not treat the absence of web results as a bug.

T7. Teams meeting Copilot is missing for pilot users

Symptom: Copilot appears in Word/Outlook but not in Teams meetings/chat. **Cause: Teams-meeting Copilot / Copilot in Teams chat/channels** have historically been **limited or unavailable** in GCC High. **Fix: Verify current status for your tenant** before promising it. If unavailable, set pilot expectations to the surfaces that work today (Word/Excel/PowerPoint/Outlook, Copilot Chat) — do not fail the pilot over a not-yet-shipped capability. (See parity notes.)

T8. A Copilot Studio / agent capability isn't available

Symptom: Teams app publishing, an M365-extending agent, Prompt Action, transfer-to-agent, or triggers/autonomous agents are missing in GCC High. **Cause:** These Copilot Studio surfaces are **restricted or unavailable** in GCC High by design. **Fix:** Design only around surfaces confirmed available in GCC High. Use `high.powerva.microsoft.us` for Copilot Studio; expect the **web-user client**, not the Teams app. Consult the parity notes' feature-limitations table and **verify for GCC High**.

T9. DLP policy "isn't doing anything"

Symptom: CUI content isn't being protected despite a DLP policy. **Cause:** Policy left in **test/simulation** mode, or scoped to the wrong locations. **Fix:** In `compliance.microsoft.us` → **DLP** → **Policies**, move `DLP-COPILOTG-CUI` from simulation to **enforce**, and confirm it targets SharePoint, OneDrive, and Teams. Confirm your SKU includes Purview DLP (G3 may need the Purview Suite GCCH add-on).

T10. Sensitivity label not appearing for users

Symptom: The mandated CUI label isn't selectable in apps. **Cause:** Label not **published** to the user (or only to a different group), or Purview Information Protection not licensed for the SKU. **Fix:** In `compliance.microsoft.us` → **Information protection** → **Label policies**, confirm the label is published to `SG-COPILOTG-Pilot` (or the user's group). Confirm Purview Information Protection is

included/added for the SKU. Allow propagation time.

T11. Remediation script made a change you didn't expect

Symptom: A site was modified when you only wanted a preview. **Cause:** The apply switch was passed instead of the default **-WhatIf**. **Fix:** Run Remediation/Set-ScopeTargeting **without** the apply switch first to preview. Only apply after review against the change ticket (R11). Roll back per your documented rollback step; re-run Validation to confirm state.

Escalation checklist

Before opening a Microsoft support case, confirm: (1) `-Environment USGov` on every connection; (2) `*.us` portals throughout; (3) eligible base + Copilot add-on licensing; (4) roles correct; (5) the capability in question is actually **available in GCC High** per the parity notes — a "missing" feature may simply not have shipped to GCC High yet. **Verify for GCC High** before treating it as a defect.

Best Practices — Microsoft 365 Copilot Secure Adoption & Governance (GCC High)

Field-tested guidance for adopting Copilot on a **GCC High** tenant without turning it into a CUI-oversharing engine. These practices assume you have followed the Implementation Guide; they are the "do this, avoid that" layer on top.

Govern before you grant

1. **Never license Copilot before you assess.** Run Discovery and remediate broad sharing *first*.

On a CUI tenant, an oversharing gap is a spillage path the moment Copilot can reason over it.

1. **Restricted SharePoint Search is a throttle, not a fix.** Use RSS to shrink Copilot's reach to a

vetted allow-list *while* you remediate — then widen the allow-list only as fast as you remediate. Do not treat RSS as a substitute for correct site permissions. **Verify RSS is available in your GCC High tenant** before relying on it.

1. **Label to the mandate, not to convenience.** Use your program's **mandated CUI taxonomy** in

Purview. Do not invent labels; do not simplify away categories your contract requires.

1. **Enforce DLP, don't just simulate it.** A DLP policy left in test mode protects nothing. Move

`DLP-COPILOTG-CUI` to enforce after reviewing simulation matches.

Use the sovereign surfaces correctly

1. `*.us` **everywhere.** Bookmark and allow-list only the GCC High portals

(`portal.office365.us`, `entra.microsoft.us`, `compliance.microsoft.us`, `security.microsoft.us`, `endpoint.microsoft.us`, `portal.azure.us`,

high.powerva.microsoft.us). Remove Commercial URLs to prevent misconfiguration and wrong-tenant sign-in.

1. **Always** `-Environment USGov`**.** Every script and every manual `Connect-MgGraph` must target US

Gov Graph (graph.microsoft.us). A silent connection to the default Global environment returns empty/incorrect results and can mask real exposure.

1. **Allow the US Gov endpoint set through filtering** (`*.microsoft.us`, `*.azure.us`, `*.usgovcloudapi.net`, the `AzureCloud.usgov*` IP ranges), not the Commercial ranges.

Respect the parity gaps (don't over-promise)

1. **Plan for web grounding OFF.** Copilot answers from tenant content by default in GCC High; expect a knowledge cutoff. Only enable web grounding if your organization explicitly accepts the data-boundary tradeoff — and document that decision.

1. **Verify Teams-meeting Copilot before promising it.** It has historically been limited/unavailable in GCC High. Set pilot expectations to what actually works today.

1. **Assume Copilot Studio / agents are restricted.** Teams app experience, Teams/M365 channel, M365-extending agents, Prompt Action, transfer-to-agent, and triggers/autonomous agents are limited or unavailable in GCC High. Design agent scenarios only around surfaces you can confirm.

1. **Re-check parity quarterly.** Wave 2 features stage into GCC High through H1 2026; update expectations and pilot scope as capabilities land. **Cite/verify — never assume parity.**

Roll out with gates

1. **Pilot with a named group** (`SG-COPILOTG-Pilot`), never the whole tenant. Group-based licensing keeps scope tight and reversible.

1. **Gate every expansion wave** on clean Validation + Report results. `SG-COPILOTG-Wave2` only gets licenses after Wave 1 validates.

1. **Keep Remediation and Set-ScopeTargeting in -WhatIf until reviewed.** Preview → review against the change ticket → apply deliberately. Never blind-apply.

Operate it as ongoing hygiene

1. **Re-run Discovery monthly.** New sites and new oversharing appear continuously; governance is a standing duty, not a launch task.

1. **Tie changes to change control.** Every label, DLP, and RSS change gets a ticket with approver, window, and rollback (global requirement G8) — because these changes alter what users *and* Copilot can find.

1. **Keep the evidence.** Retain Discovery baselines and Validation/Report output; on a CUI tenant

this is your audit trail that Copilot was adopted under control.

Deliverables Summary — Microsoft 365 Copilot Secure Adoption & Governance (GCC High)

Everything included in the Government (GCC High) edition, and how the pieces fit together.

Documents

Document	What it covers
Solution Overview (`01-solution-overview.md`)	What the solution does; **Commercial vs GCC High — what's different**; the Copilot-availability caveat (GA in GCC High, Dec 2025); named objects; deployment model
Requirements Guide (`02-requirements.md`)	Every prerequisite — GCC High tenant, G3/G5 Gov licensing + Copilot add-on, roles, sovereign portal access, US Gov endpoints, Graph `-Environment USGov`, CUI label taxonomy — each with Verify / Implement
Implementation Guide (`03-implementation.md`)	Ordered click-by-click on the `*.us` portals: Assess → Configure (labels, DLP, Restricted SharePoint Search, remediation) → Pilot → Validate → Expand, with GCC-High caveats inline
Testing Guide (`05-testing.md`)	Pass/fail suites: governance posture, oversharing behavior (the core proof), parity expectations, evidence report
Troubleshooting Guide (`06-troubleshooting.md`)	GCC-High-specific gotchas — wrong environment, wrong portal, RSS availability, licensing, web grounding, agent limits
Best Practices (`07-best-practices.md`)	Govern-before-grant, sovereign-surface discipline, respecting parity gaps, gated rollout, ongoing hygiene
GCC High Parity Notes (`gcc-high-parity-notes.md`)	**Cited** reference for every Commercial-vs-GCC-High difference
Executive Summary (`executive-summary.md`)	One-page leadership brief

PowerShell scripts (`scripts/`)

All scripts connect to **US Gov Microsoft Graph** (`-Environment USGov`). Discovery, Validation, and Report are **read-only**. Remediation and Set-ScopeTargeting **default to** `-WhatIf` (preview only) and require an explicit, deliberate apply.

Script	Purpose	Safety
`COPILOTG-Discovery.ps1`	Enumerate oversharing exposure, unlabeled sites, OneDrive sharing, Copilot license assignments	Read-only
`COPILOTG-Validation.ps1`	Pass/fail checks: RSS on & scoped, CUI label published, DLP enforced, license scope, allow-list hygiene	Read-only
`COPILOTG-Report.ps1`	Consolidated evidence report (posture + validation) for change record / sign-off	Read-only
`COPILOTG-Remediation.ps1`	Flag/remove broadly-shared sites from the allow-list, sites missing labels	**-WhatIf by default**
`COPILOTG-Set-ScopeTargeting.ps1`	Build/populate `SG-COPILOTG-Pilot` / `SG-COPILOTG-Wave2` for staged rollout	**-WhatIf by default**

How they work together

1. **Discovery** establishes the baseline (Assess).
2. **Remediation** (preview → apply) and the portal steps close the gaps (Configure).
3. **Set-ScopeTargeting** builds the pilot group; you license it (Pilot).
4. **Validation** + **Report** prove the guardrails hold (Validate) — the gate before you **Expand**.

Named objects (used consistently across all deliverables)

- `SG-COPILOTG-Pilot`, `SG-COPILOTG-Wave2` — staged-rollout security groups
- `DLP-COPILOTG-CUI` — DLP policy keyed to the CUI sensitivity label
- `Copilot Search Allowed Sites` — Restricted SharePoint Search allow-list
- CUI sensitivity label — **your organization's mandated taxonomy** (placeholder shown as `CUI//BASIC`)

Definition of done

Discovery baseline captured; guardrails configured on the `*.us` portals; pilot licensed to `SG-COPILOTG-Pilot`; Validation all-pass and oversharing spot-check confirms no leakage; Report attached to the change ticket; parity gaps recorded as observed. Then, and only then, expand.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

COPILOTG-Discovery.ps1

Purpose: Enumerates the Copilot oversharing exposure on a Microsoft 365 GCC High tenant BEFORE any user is licensed: SharePoint sites shared broadly, sites without sensitivity labels, and current Microsoft 365 Copilot license assignments. Read-only. Replace the sample values (e.g. the output folder) with your own — use plain text like 'your-output-folder'. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\COPILOTG-Discovery.ps1 (Microsoft Graph scopes: Sites.Read.All, Directory.Read.All, Organization.Read.All; connects with -Environment USGov to the US Gov Graph endpoint.) EXPECTED RESULTS A console summary plus a CSV of flagged sites and Copilot license counts. Sites flagged as broadly shared are your remediation backlog. PASS = report generated and reviewed; FAIL = connection not on USGov (empty/incorrect results) — see the Troubleshooting guide T1. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

How to run: powershell -ExecutionPolicy Bypass -File .\COPILOTG-Discovery.ps1 (Microsoft Graph scopes: Sites.Read.All, Directory.Read.All, Organization.Read.All; connects with -Environment USGov to the US Gov Graph endpoint.) EXPECTED RESULTS A console summary plus a CSV of flagged sites and Copilot license counts. Sites flagged as broadly shared are your remediation backlog. PASS = report generated and reviewed; FAIL = connection not on USGov (empty/incorrect results) — see the Troubleshooting guide T1. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

COPILOTG-Remediation.ps1

Purpose: Flags — and, only when explicitly told to, removes — broadly-shared or unlabeled sites from the Restricted SharePoint Search allow-list so Copilot cannot reach unremediated content. Runs in preview (-WhatIf) by DEFAULT and changes nothing until you pass -Apply. Substitute the sample allow-list name for your own — plain text like 'your-allow-list', no angle brackets. HOW TO RUN Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\COPILOTG-Remediation.ps1 Apply (deliberate, after review against your change ticket): powershell -ExecutionPolicy Bypass -File .\COPILOTG-Remediation.ps1 -Apply (Graph scopes: Sites.Read.All, Sites.FullControl.All for apply; connects with -Environment USGov.) EXPECTED RESULTS In preview: a list of what WOULD change, no modifications. On -Apply: the reviewed changes are made and logged. PASS = preview matches your ticket, apply completes; FAIL = not on USGov (see Troubleshooting T1) or insufficient rights. .NOTES White-label — the repeatable way. Read-only by default against Microsoft Graph US Gov endpoints; writes only with -Apply. #>

How to run: Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\COPILOTG-Remediation.ps1 Apply (deliberate, after review against your change ticket): powershell -ExecutionPolicy Bypass -File .\COPILOTG-Remediation.ps1 -Apply (Graph scopes: Sites.Read.All, Sites.FullControl.All for apply; connects with -Environment USGov.) EXPECTED RESULTS In preview: a list of what WOULD change, no modifications. On -Apply: the reviewed changes are made and logged. PASS = preview matches your ticket, apply completes; FAIL = not on USGov (see Troubleshooting T1) or insufficient rights. .NOTES White-label — the repeatable way. Read-only by default against Microsoft Graph US Gov endpoints; writes only with -Apply. #>

COPILOTG-Report.ps1

Purpose: Produces a single evidence report (HTML + CSV) combining posture and validation signals for the change record and leadership sign-off: tenant/environment, Copilot license counts, site count, and governance checklist status. Read-only. Replace sample values (e.g. output path) with your own — plain text like 'your-report-folder'. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\COPILOTG-Report.ps1 (Graph scopes: Sites.Read.All, Group.Read.All, Directory.Read.All, Organization.Read.All; connects with -Environment USGov.) EXPECTED RESULTS An HTML report and CSV in the output folder. PASS = report generated; attach it to the change ticket. FAIL = connection not on USGov — see Troubleshooting T1. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

How to run: powershell -ExecutionPolicy Bypass -File .\COPILOTG-Report.ps1 (Graph scopes: Sites.Read.All, Group.Read.All, Directory.Read.All, Organization.Read.All; connects with -Environment USGov.) EXPECTED RESULTS An HTML report and CSV in the output folder. PASS = report generated; attach it to the change ticket. FAIL = connection not on USGov — see Troubleshooting T1. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

COPILOTG-Set-ScopeTargeting.ps1

Purpose: Creates and populates the staged-rollout Entra security groups (SG-COPILOTG-Pilot, SG-COPILOTG-Wave2) used to scope Microsoft 365 Copilot licensing on a GCC High tenant. Runs in preview (-WhatIf) by DEFAULT and changes nothing until you pass -Apply. Provide members via a CSV of UPNs — replace the sample path with your own, plain text like 'your-members.csv'. HOW TO RUN Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\COPILOTG-Set-ScopeTargeting.ps1 -GroupName 'SG-COPILOTG-Pilot' -MembersCsv .\pilot-members.csv Apply (deliberate): powershell -ExecutionPolicy Bypass -File .\COPILOTG-Set-ScopeTargeting.ps1 -GroupName 'SG-COPILOTG-Pilot' -MembersCsv .\pilot-members.csv -Apply (Graph scopes: Group.ReadWrite.All, User.Read.All for apply; connects with -Environment USGov.) EXPECTED RESULTS In preview: the group + membership that WOULD be created, no changes. On -Apply: the group is created/updated. PASS = preview matches intent, apply completes; FAIL = not on USGov (see Troubleshooting T1) or insufficient rights. .NOTES White-label — the repeatable way. Read-only by default against Microsoft Graph US Gov endpoints; writes only with -Apply. #>

How to run: Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\COPILOTG-Set-ScopeTargeting.ps1 -GroupName 'SG-COPILOTG-Pilot' -MembersCsv .\pilot-members.csv Apply (deliberate): powershell -ExecutionPolicy Bypass -File .\COPILOTG-Set-ScopeTargeting.ps1 -GroupName 'SG-COPILOTG-Pilot' -MembersCsv .\pilot-members.csv -Apply (Graph scopes: Group.ReadWrite.All, User.Read.All for apply; connects with -Environment USGov.) EXPECTED RESULTS In preview: the group + membership that WOULD be created, no changes. On -Apply: the group is created/updated. PASS = preview matches intent, apply completes; FAIL = not on USGov (see Troubleshooting T1) or insufficient rights. .NOTES White-label — the repeatable way. Read-only by default against Microsoft Graph US Gov endpoints; writes only with -Apply. #>

COPILOTG-Validation.ps1

Purpose: Checks that the guardrails are in place before expanding Copilot: US Gov connection confirmed, CUI sensitivity label published, DLP policy present, Copilot licenses scoped to the intended group, and no

broadly-shared site left in Copilot's reach. Read-only. Substitute the sample names for your own — plain text like 'your-pilot-group', not angle brackets. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\COPILOTG-Validation.ps1 -PilotGroupName 'SG-COPILOTG-Pilot' (Graph scopes: Sites.Read.All, Group.Read.All, Directory.Read.All, Policy.Read.All; connects with -Environment USGov.) EXPECTED RESULTS A PASS/FAIL line per check and an overall gate result. Overall PASS = safe to proceed to the next wave. Any FAIL = remediate and re-run; do NOT expand. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

How to run: powershell -ExecutionPolicy Bypass -File .\COPILOTG-Validation.ps1 -PilotGroupName 'SG-COPILOTG-Pilot' (Graph scopes: Sites.Read.All, Group.Read.All, Directory.Read.All, Policy.Read.All; connects with -Environment USGov.) EXPECTED RESULTS A PASS/FAIL line per check and an overall gate result. Overall PASS = safe to proceed to the next wave. Any FAIL = remediate and re-run; do NOT expand. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>